

- Entity coding standards and list of entity-approved software development languages.
  - Documentation of security certification for completed systems and component-related code.
  - Development designs used to validate security and functionality throughout the supply chain.
  - Documentation of risk assessment related to use of or switch to a DevOps approach and effectiveness of controls.
1. Assess management's ability to provide policies, procedures, and practices to oversee and manage development activities. Consider management's actions to
    - a. Provide access to training in secure design and coding techniques to those responsible for development activities to securely design and address key issues early in the development process for entities that develop or modify their own systems and software.
    - b. Maintain and follow policies, standards, and procedures documented for developing systems and components incorporating the entity's requirements for confidentiality, integrity, availability, and resilience.
    - c. Appropriately manage risks (e.g., eliminating inaccurate techniques or outdated tools and prototypes) with use of any additional design and coding techniques beyond standard coding techniques (e.g., computer-aided design) and prototypes.
    - d. Develop, as part of the SDLC, a trustworthy system that meets specific security and other critical requirements defined and set by entity management.
    - e. Employ secure program coding practices to help develop a trustworthy system.
    - f. Incorporate supply chain processes when choosing system and network components.
    - g. Plan for maintenance activities from the outset of the development process to address secure continuity of operations.
  2. Assess management's development of standards and controls. Consider the following:
    - a. Procedures for managing changes during the development process, that address:
      - System controls.
      - Quality management.
      - Release management.
      - Documentation.
      - Reporting.
    - b. Documentation of reasons for using specific programming styles and languages on a project or service in project documentation.
    - c. Documentation of completed systems and component-related code that have passed security certification in program libraries as discussed in the "[Additional Control Considerations in Change Management](#)" section of this booklet.
    - d. Design of information systems, components, and elements to be difficult to disable (e.g., tamper-proofing techniques), and, if they are disabled, trigger notification methods such as audit trails, tamper evidence, or alarms.
    - e. Design of delivery mechanisms (e.g., downloads for software) to avoid unnecessary exposure or access to the supply chain and systems or components traversing the supply chain.

- f. Design of relevant validation mechanisms to be used during implementation and operation.
- g. Agreement with partners on standards and controls used in customized system and component development throughout the supply chain.
- h. Work with suppliers and partners to ensure that critical systems and components are identified.
- i. Validate that suppliers or the entity itself has a continued ability to maintain customized systems and components that are critical to the entity's operations.

**Objective 11: Evaluate whether management maintains formal testing processes and standards to govern the effectiveness of testing internally and externally developed systems and components. (Section V.B “[Testing](#)”)**

Examiners should review the following:

- Testing policies and procedures to confirm that systems and components meet the entity's requirements.
  - Testing scope documentation, including for application interoperability and discovery of vulnerabilities.
  - Documentation regarding appropriate controls and approvals over the use of production data in testing.
  - Documentation of the type of testing, testing results, corrective actions, and testing completion.
  - Documentation of testing for any new controls added to systems and components to avoid conflicts.
  - Updates to manuals and training plans after testing.
1. Assess whether management appropriately tests systems and components to identify and mitigate risks or vulnerabilities before deployment. Consider the following management actions:
    - a. Determining the need for use of production data in testing and employing appropriate controls (e.g., masking) if its use is deemed necessary.
    - b. Documenting approval of the use of nonsanitized data by the board when sanitizing data is not feasible and implementing and maintaining controls similar to those used in the production environment to appropriately protect the data for compliance with legal and regulatory requirements.
    - c. Performing additional acceptance tests of new controls if they are added to the system to help ensure that new controls meet security specifications and do not conflict with or invalidate existing controls or functionality.
    - d. Establishing a methodical process to define and conduct testing necessary to demonstrate the effectiveness of a developed system or component.
    - e. Implementing practices to document, report, and address identified issues, including security-related issues, in a timely manner, regardless of the testing methods used.
    - f. Reviewing and finalizing all supporting documentation, such as user, operator, and maintenance manuals as well as any conversion, implementation, and training plans

- associated with a new release or significant update during the implementation and assessment phase.
2. Assess management's oversight and control of DevOps and DevSecOps activities. Consider management's activities to
    - a. Assess risks involved in using or switching to a DevOps approach and implementing appropriate controls.
    - b. Consider controls to secure the CI/CD pipeline process, such as the following:
      - Hardening servers hosting code and artifact repositories.
      - Securing credentials (e.g., authorization tokens) used for accessing repositories.
      - Implementing controls on who can check in and check out artifacts in container image registries.
      - Logging all code and build update activities.
      - Sending build reports to developers and stopping further pipeline tasks when a build or test fails in the CI pipeline and configuring code repositories to automatically block all subsequent pull requests from CD or continuous deployment pipeline until issues are resolved.
      - Sending build reports to the security team and stop further pipeline tasks when a code or build audit fails.
      - Ensuring that developers can only access the application code.
      - Digitally signing (preferably multiparty digital signing) the release artifact during each required CI/CD stage during the build and release process.
      - Verifying that all required digital signatures are present during production release to ensure that no one bypasses the pipeline.
  3. Assess management's oversight of database development. Consider management's actions to
    - a. Understand the different types, structures, and uses of databases to effectively mitigate the risks of database development.
    - b. Understand the benefits, limitations, and appropriate controls for the type of database used.
    - c. Choose the appropriate database to meet business and stakeholder objectives.
    - d. Consider access needed and services (e.g., management, analysis, and data services) that the databases will provide for internal and external customers.

**Objective 12: Evaluate whether management establishes acquisition processes that are commensurate with the entity's business and procurement needs and assesses and mitigates procurement risks associated with overall entity strategic, regulatory, and operational risks. (Section VI "[Acquisition](#)")**

Examiners should review the following:

- Project requests and plans related to acquisition.

- Risk assessments, strategic and business plans, and due diligence activities, including meeting minutes related to the acquisition process.
  - Contracts and licensing agreements for appropriate provisions, responsibilities and accountability, and mitigation strategies.
  - Acquisition-related requests containing documented evaluation criteria and sufficient information for decision-making.
  - Documentation standards and procedures, including for updating documentation.
  - Stakeholder training and guidance in the acquisition process.
  - Audits related to the acquisition process and procurement.
1. Assess management's mitigation of the risks associated with acquisition of systems or components. Consider its actions to coordinate implementation of the following:
    - a. Ascertaining whether the product specifications are "fit for purpose" and meet the entity's requirements, (regardless of whether the entity purchases directly from OEM partners or a secondary market) and are addressed in agreements with supply chain partners.
    - b. Developing policies, standards, and procedures to effectively carry out the entity's procurement processes aligned with the entity's acquisition activities.
    - c. Performing rigorous due diligence reviews of potential suppliers.
    - d. Aligning the depth of the due diligence evaluation with the complexity, scope, and risk assigned by the risk assessment for the system or component to be procured.
    - e. Implementing contract and licensing processes.
    - f. Reviewing contracts and licensing agreements to help ensure that the rights and responsibilities of each party are clear and identify accountability.
  2. Assess management's procurement process. Consider management actions to
    - a. Develop and manage an effective IT procurement process to meet the entity's acquisition and contract fulfillment needs.
    - b. Follow a structured procurement process for any IT procurement, but particularly when procuring significant systems, components, products, and services to help ensure that each step in the process is addressed.
    - c. Ascertain that, at a minimum, procured hardware, software, and services adhere to entity standards.
  3. Assess whether management has established policies, standards, and procedures to better assist in the effective and consistent management of the entity's acquisition process. Consider management's actions to
    - a. Provide for acquisition policies, standards, and procedures that promote the
      - Definition of a process for issuing information requests (e.g., RFIs and RFPs) to third parties.
      - Performance of appropriate third-party due diligence processes.

- Negotiation of the contract to ensure that it contains terms amenable to entity management and types of IT-related provisions to consider before contract execution.
    - Establishment of processes for the entity's contract signature authority and process for specialist review (e.g., subject matter experts, key stakeholder, legal, and compliance) of IT-related contracts before approval and signature.
    - Validation of the systems, components, products, and services to ensure that they meet user requirements before acceptance.
    - Transferability or portability of systems, components, products, and services if a third-party relationship is discontinued.
  - b. Understand the following risks and their effects on the business before entering foreign-based third-party relationships:
    - Legal.
    - Country.
    - Currency (or exchange rate).
    - Geopolitical.
    - Resilience.
  - c. Identify, plan, and address the root causes of foreign-based risks or crises to minimize their effects on the entity's operations.
  - d. Plan for maintenance activities from the outset of the acquisition process to address secure continuity of operations.
- 4. Assess management's project selection process. Consider management's actions to
  - a. Consider business needs, third-party solutions, specifications, and costs.
  - b. Involve appropriate stakeholders in defining the entity's IT, information security, and functional requirements, and that the project meets applicable legal and regulatory expectations.
  - c. Identify the entity's needs to avoid a third party's confusion with a request for information and omission of critical information needed for decision-making.
  - d. Refrain from making assumptions based on third-party responses when management receives information from them, and ask follow-up questions to clarify concerns or solicit more information.
  - e. Determine when a relationship is established and a contract is created when using an RFQ.
  - f. Consult with the entity's legal counsel to identify and resolve contractual issues.
  - g. Implement a formal process for evaluating information, proposals, and quotes received from the RFIs, RFPs, and RFQs that includes key information to help management select appropriate providers.
- 5. Assess management's oversight of contracts and agreements. Consider management's actions to
  - a. Implement standards and procedures for documentation, review, and approval.
  - b. Consult with legal representation to determine the entity's rights and enforceability of terms, because agreements may not always be enforceable in a court of law.

- c. Identify each of the agreements and contracts that help management complete the evaluation and selection steps.
  - d. Validate that contracts have clauses that address relevant security and privacy standards with third-party service providers or vendors that process, store, or transmit sensitive customer data or provide critical services to meet applicable legal and regulatory requirements.
  - e. Consider providing training and guidance to support a structured approach to SOW development.
  - f. Involve appropriate personnel (e.g., relevant stakeholders) in developing an SOW and establish an appropriate senior management review and approval process.
  - g. Validate that the provider's needs and requirements (e.g., price, security, and interoperability) are met in order to provide for delivery of a quality product or service.
  - h. Establish clear and measurable expectations for the services provided, recourse when expectations are not met, and accountability for both parties if management is procuring services related to a system or component.
  - i. Link SLAs to clauses in the contract regarding incentives, penalties, and contract termination to protect the entity in the event of third-party performance failures.
  - j. Outline rights in contracts, including licenses, if applicable, when using systems and components developed by third parties.
  - k. Consider risks and address them through contract clauses (e.g., representations, warranties, and indemnifications to vendor liability limitations, information security, and agreement modifications).
  - l. Ensure that contracts have clauses that address relevant security and privacy standards with third-party service providers or vendors that process, store, or transmit sensitive customer data or provide critical services to meet applicable legal and regulatory requirements.
  - m. Consider contract clauses that allow for a contract to be revisited if a key subcontractor changes, which may affect critical services in the entity.
  - n. Determine during contract negotiation whether management is willing to accept or can mitigate the risks related to systems or components without requested terms in situations when third parties cannot or will not agree to the terms an entity sets out in the draft contract.
  - o. Document, with appropriate approvals consistent with the entity's policies and governance structure, any accepted risk or compensating control factors if third parties cannot or will not agree to the terms an entity sets out in the draft contract.
  - p. Validate that the third-party software developer's development policies and standards meet or exceed those of the entity.
  - q. Validate that third-party developers are following industry standards, at a minimum.
  - r. Negotiate terms, if possible, that would enable another third-party service provider to access an affected system or component and help management in the conversion without violating agreement restrictions.
  - s. Consider alternative solutions if management cannot accept or mitigate the risk.
6. Assess whether management has provided appropriate oversight of escrow arrangements with third parties. Consider management's actions to

- a. Validate, at least annually, that the third party maintains a current version of the source code for software in escrow.
  - b. Consider incorporating provisions into escrow agreements such as
    - Definitions of minimum programming and system and component documentation.
    - Definitions of system and component maintenance procedures.
    - Conditions that should be present before an entity can access the source code and related documentation.
    - Assurances that the escrow agent will hold current versions of the source code and related documentation to validate that escrowed information is updated whenever significant program changes are made.
    - Arrangements for auditing or testing the integrity of the escrowed code.
    - Descriptions of the source code and related documentation and the storage type or location (e.g., magnetic tape or cloud) containing it.
    - Assurances that the storage type or location containing the source code and related documentation is accessible, operable, and compatible with an entity's existing IT environment.
    - Assurances that the source code can be compiled into executable code.
    - If the escrow agent is based outside the United States, consideration of the practical and legal implications of establishing foreign-based escrow arrangements.
7. Assess management's exit strategy plan for transitioning or terminating a product, service, or third-party relationship. Consider management's actions to
  - a. Help minimize disruption to an entity's operations.
  - b. Develop an initial exit strategy during the procurement process to address a situation when a third party cannot or does not meet the contract terms.
  - c. Consider identifying alternative third parties that provide similar products and services at the onset of the relationship.

***Objective 13: Evaluate whether management establishes formal policies, procedures, and responsibilities for managing systems and component maintenance, and processes that ensure the availability and continued operability of systems and components. (Section VII, "[Maintenance](#)")***

Examiners should review the following:

- System and component inventory for key information (e.g., version, update, and patch level) to identify and address vulnerabilities.
- Maintenance plans, including maintenance schedule and logs, vendor and developer recommendations, cost-benefit analyses, operational risks, availability of qualified personnel, and other relevant industry factors.
- Change authorizations and review any reports for identification of anomalous activity.
- Change types and risk assessment processes for those changes.



- Configuration management practices to validate appropriate implementation and enforcement of established change processes.
  - Vulnerability and threat identification processes and remediation plans.
  - Reports to board and senior management regarding maintenance issues.
  - IT asset inventory including considerations for EOL, vulnerability management, planned obsolescence, and legacy systems and components.
  - Termination, disposal, and off-boarding processes of systems, components, and third-party relationships.
  - Maintenance documentation for any system, component, and configuration updates.
1. Assess whether management provides for development of policies for the maintenance of systems and components, including remote access for performing maintenance, roles and responsibilities of personnel with access for maintenance activities, and monitoring and audit mechanisms of maintenance activities. Consider management's actions to
    - a. Analyze and understand the costs of maintenance (e.g., budget, time, or personnel) versus the costs of not performing maintenance (e.g., system failures, data breaches, and customer dissatisfaction), and track costs for reporting purposes.
    - b. Plan for maintenance activities from the outset of the acquisition and development processes to address secure continuity of operations.
    - c. Perform preventive maintenance throughout an IT asset's useful life to prevent or minimize catastrophic failure and promote confidentiality, integrity, availability, and resilience.
    - d. Consider vendor or developer recommendations, cost-benefit analyses, operational risks, availability of qualified personnel, and other relevant industry factors (e.g., emerging technologies and threats) when developing the schedule for the maintenance plan.
    - e. Track system and component information, such as version, update, and patch level, as tracking and using this information helps personnel manage (e.g., through regular updates, data protection, and digital forensics) technology vulnerabilities.
    - f. Develop a process for identifying maintenance and vulnerability information and mechanisms for responding to user questions about developed or acquired IoT systems and components.
    - g. Validate that while a system or component is in use, it is appropriately maintained and updated through preventative maintenance and change management.
    - h. Establish a preventive maintenance plan, especially for mission-critical systems and components.
    - i. Maintain logs of maintenance activities and perform reviews of those logs as needed for authorization of changes, as well as anomalous or malicious activity.
    - j. Maintain awareness of the risks associated with unauthorized, untested, or unplanned changes.
    - k. Consider the capability of the product to receive, verify, and apply verified updates for configuration, patch, and vulnerability management for developed or acquired products.
    - l. Implement processes to manage changes regardless of whether the system or component was developed internally.



- m. Establish configuration management processes for developed and procured systems and components and help ensure that those processes are followed and enforced.
  - n. Validate that only authorized personnel implement configuration changes and make those changes only to designated systems.
  - o. Identify the sources of vulnerability information and threat intelligence for the entity's systems and components.
  - p. Receive the results of internal or external vulnerability scanning and penetration testing and identify remediation plans to resolve any issues detected through these tests.
  - q. Evaluate and mitigate the risk associated with the vulnerability to the entity's affected systems and components when obtaining vulnerability and threat intelligence from vendors, developers, third parties, and other sources.
  - r. Report the results of the testing and the remediation plans to the board.
  - s. Validate that the entity's patch management processes include procedures for identifying, evaluating, approving, testing, installing, and documenting patches or updates for systems and components.
2. Assess management's oversight of end-of-life activities. Consider management's actions to
- a. Maintain an accurate inventory of the entity's IT assets, including systems and components, regardless of whether they are developed internally or acquired from a third party.
  - b. Account for planned obsolescence if systems or components are developed internally.
  - c. Include a contract clause regarding advanced notification before the vendor's sunset timeline of an IT asset if a vendor decides not to replace, upgrade, or continue to support the asset.
  - d. Implement a process to determine EOL decisions (e.g., replace, upgrade, or migrate to a new system) before a system or component's EOL.
  - e. Document and monitor depreciation and obsolescence schedules of the entity's systems and components in its ITAM inventory to plan for EOL, as a part of its ITAM process.
  - f. Consider EOL risks tied to interconnections in the supply chain derived from maintaining legacy systems and components for an extended period of time.
  - g. Address EOL and the use of legacy systems and components, including time frames for necessary replacement or upgrade in contracts between the entity and its supply chain partners.
  - h. Address EOL risks related to the use of legacy systems and components by mitigation strategies such as the following:
    - Assess the risks of continued use of aging, outdated, and unsupported systems and components.
    - Consider transitioning to newer, supported systems and components.
    - Employ compensating controls.

3. Assess management's practices for termination and disposal of systems and components. Consider management's actions to
  - a. Implement appropriate termination and off-boarding procedures.
  - b. Include appropriate clauses in contracts with third parties to manage the termination of services, including related relationships (e.g., affiliates, subcontractors), if necessary. Clauses and contracts should address
    - Maintaining confidentiality, integrity, availability, and resilience of data and operations throughout the off-boarding process.
    - Specifying criteria defining termination.
  - c. Develop and implement procedures for the following:
    - Shutdown (i.e., sunset) of the systems and components.
    - Identification of the tasks involved.
    - Preservation and identification of the data and its disposition (i.e., archival or transfer).
    - Secure disposal of unnecessary systems and components (e.g., hardware and software).
  - d. Validate that appropriate personnel are aware of the procedures to coordinate the orderly disposition of the system, its components, and the data.
  - e. Develop and implement procedures to help ensure that the entity's critical or sensitive data and documents are removed (e.g., wiped, sanitized, or otherwise destroyed) logically and physically from the system and components before disposal.
  - f. Validate that data or documents maintained by the third party on behalf of the entity are addressed by the entity's requirements in the termination and disposal clauses of the contract.
4. Assess management's oversight of maintenance documentation, including working with third parties to help ensure that the entity receives current system, component, and user maintenance documentation.

**Objective 14: Evaluate whether management establishes a formal process for the review, justification, approval, implementation, testing, and disposition of changes, and maintains confidentiality, integrity, availability, and resilience in the change management process. (Section VII.B, "[Change Management](#)")**

Examiners should review the following:

- Change requests demonstrating prioritization, categorization, tracking, and reporting.
- Change control process, including for back-out plans and inventory, for all change types.
- Change management controls, including change logs, access control, and version control features.
- Risk assessment and change documentation, including approvals.
- Training for change management.
- Conversion plans and coordination with conversion partners and stakeholders.
- Reviews of change control processes for comprehensiveness and ongoing effectiveness, including review of all significant change reports and related documentation.